CIS437 - Cloud Computing

– Cloud Security II –

Identity, Access Management, and Data Protection

Instructor: Yong Zhuang

yong.zhuang@gvsu.edu

Based on the original version by Professor Erik Fredericks

Last Class

- Security Goals: CIA
- Threats and Common Cloud Security Risks
- Vulnerabilities and Patching
- Shared Responsibility
- Customer Security Responsibilities
- Defense in Depth
- Logging and Monitoring

Last Class Practice: Who Is Responsible: Provider or Customer?



- **Scenario 1:** A physical disk fails inside a Google data center.
  Who is responsible for the physical hardware?
- **Scenario 2:** A Compute Engine VM is configured with the password password123.
  Who is responsible for the weak authentication?
- **Scenario 3:** A developer accidentally makes a Cloud Storage bucket public.
  Who is responsible for the access configuration?
- **Scenario 4:** The physical network infrastructure supporting Cloud Storage has a hardware problem.
  Who is responsible for the underlying physical network?
- **Scenario 5:** A developer installs a malicious application dependency that steals a service credential.
  Who is responsible for managing this application/dependency risk?

Agenda

- Authentication vs. Authorization
- Identity and Access Management (IAM)
- IAM Policies and Roles
- Cloud Identity and Groups
- Service Accounts
- Credentials and Secrets
- Encryption and Key Management
- Security Best Practices
- Privacy

Authentication vs. Authorization

Authentication

- Verifies identity
- “Who are you?”
- Examples: password, MFA, security key

Authorization

- Determines permissions
- “What are you allowed to do?”
- Examples: view a bucket, start a VM, modify IAM policy

Then add one simple example at the bottom:

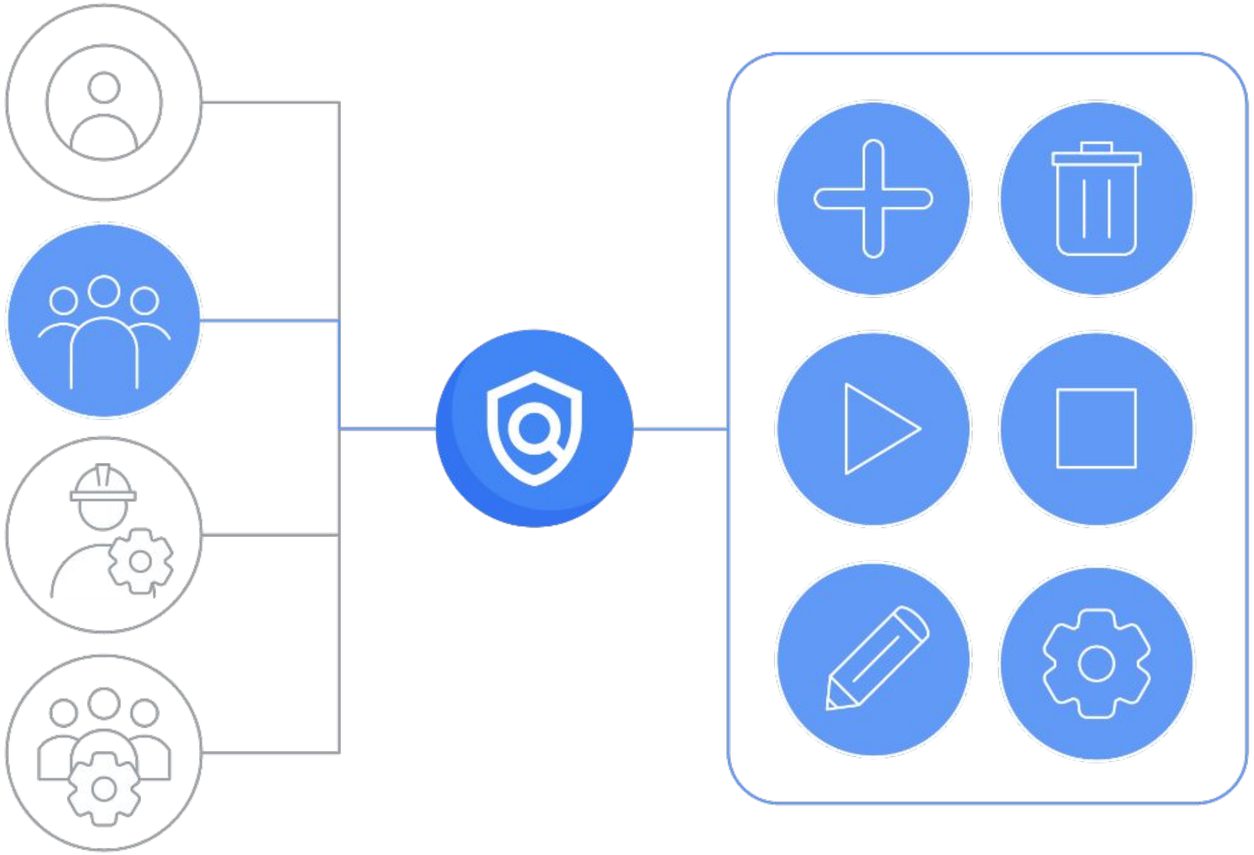
Example:

Logging into Google Cloud = authentication

Being allowed to create a VM = authorization

Identity and Access Management applies policies

IAM policies define who can do what on which resources

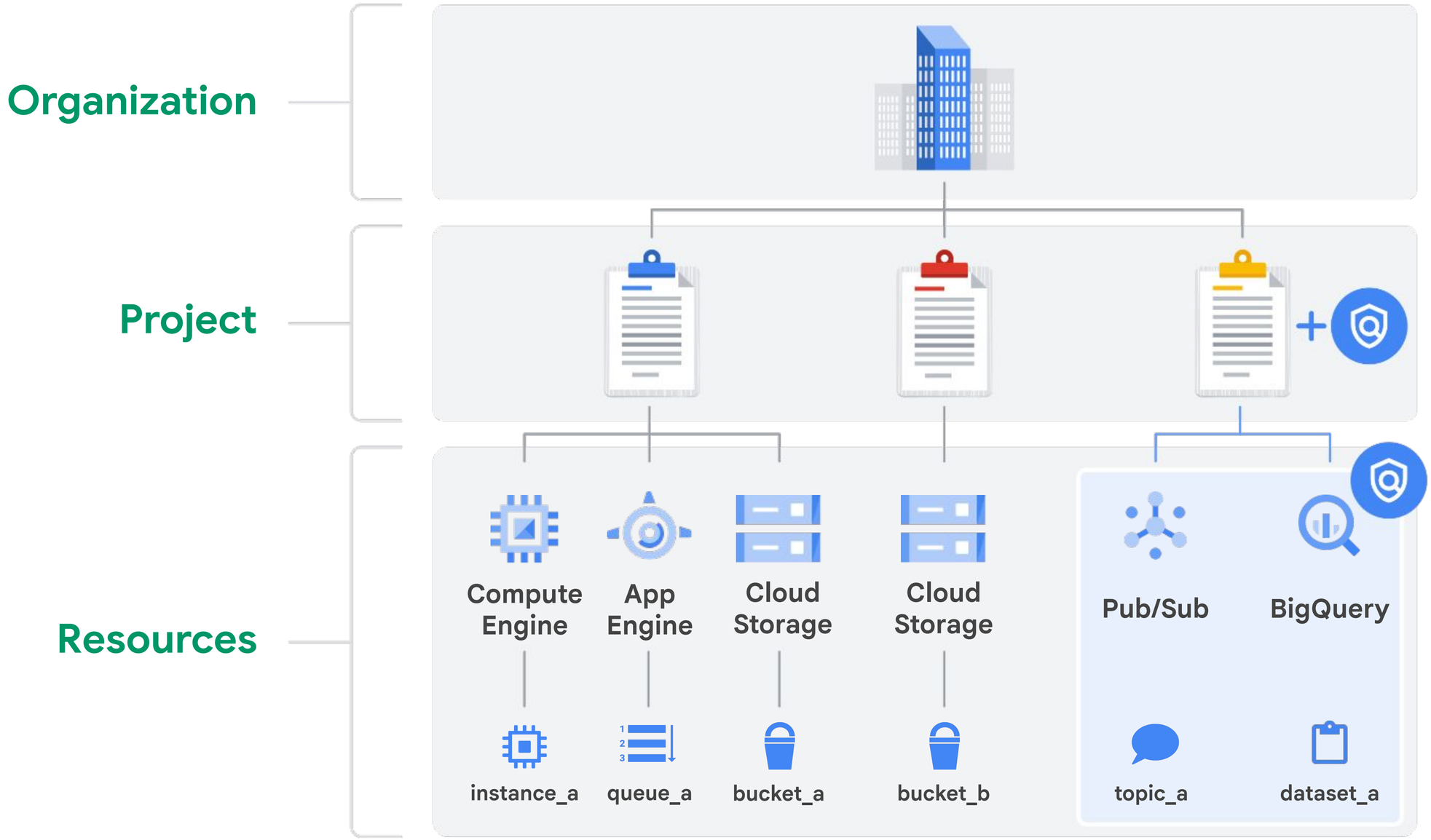


who → Google Account, Google Group, service account, Cloud Identity domain

Can do what → role, which contains permissions

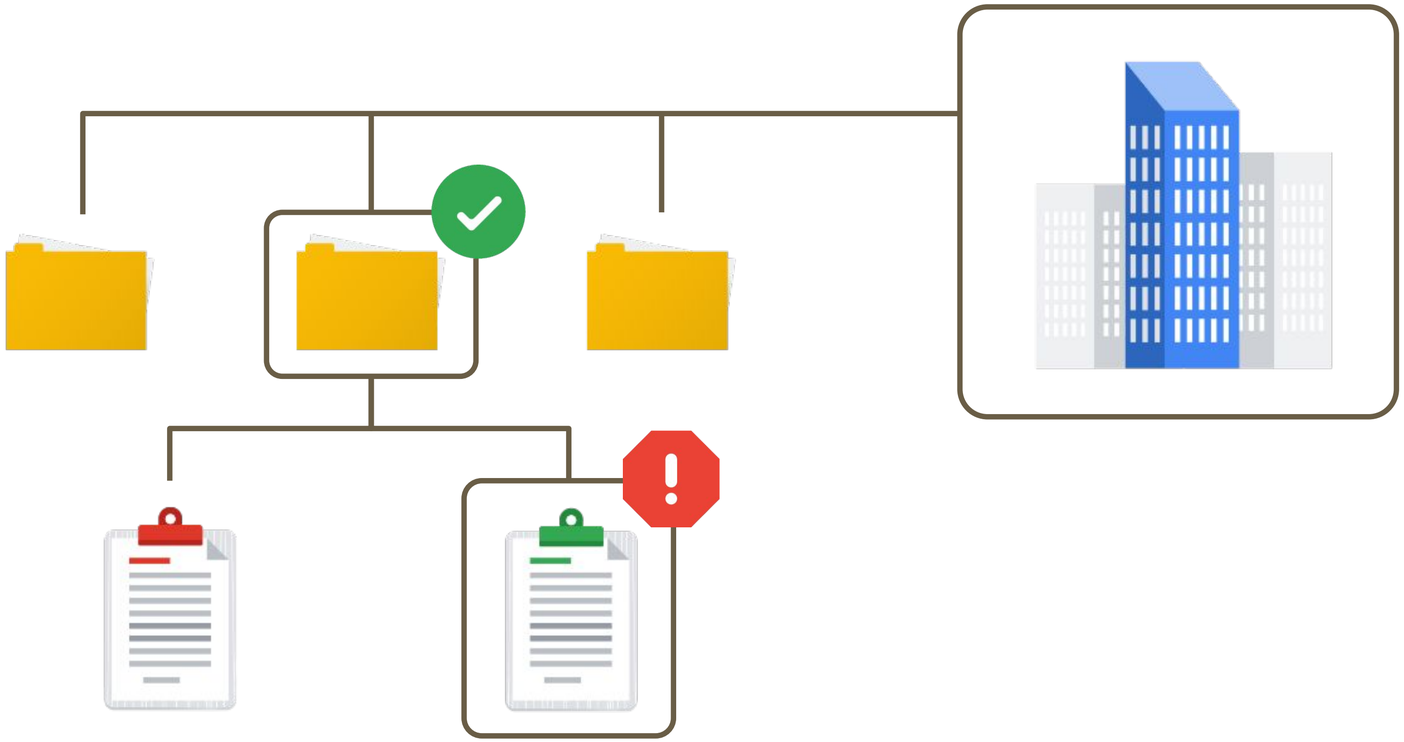
on which resource → project, VM, bucket, dataset, and so on

Policies are managed and applied by IAM



Deny policies prevent specific IAM permissions

A deny policy overrides any existing allow policy regardless of the IAM role granted



There are three kinds of IAM roles

Basic
IAM role



Predefined
IAM role



Custom
IAM role



Basic IAM roles are broad in scope

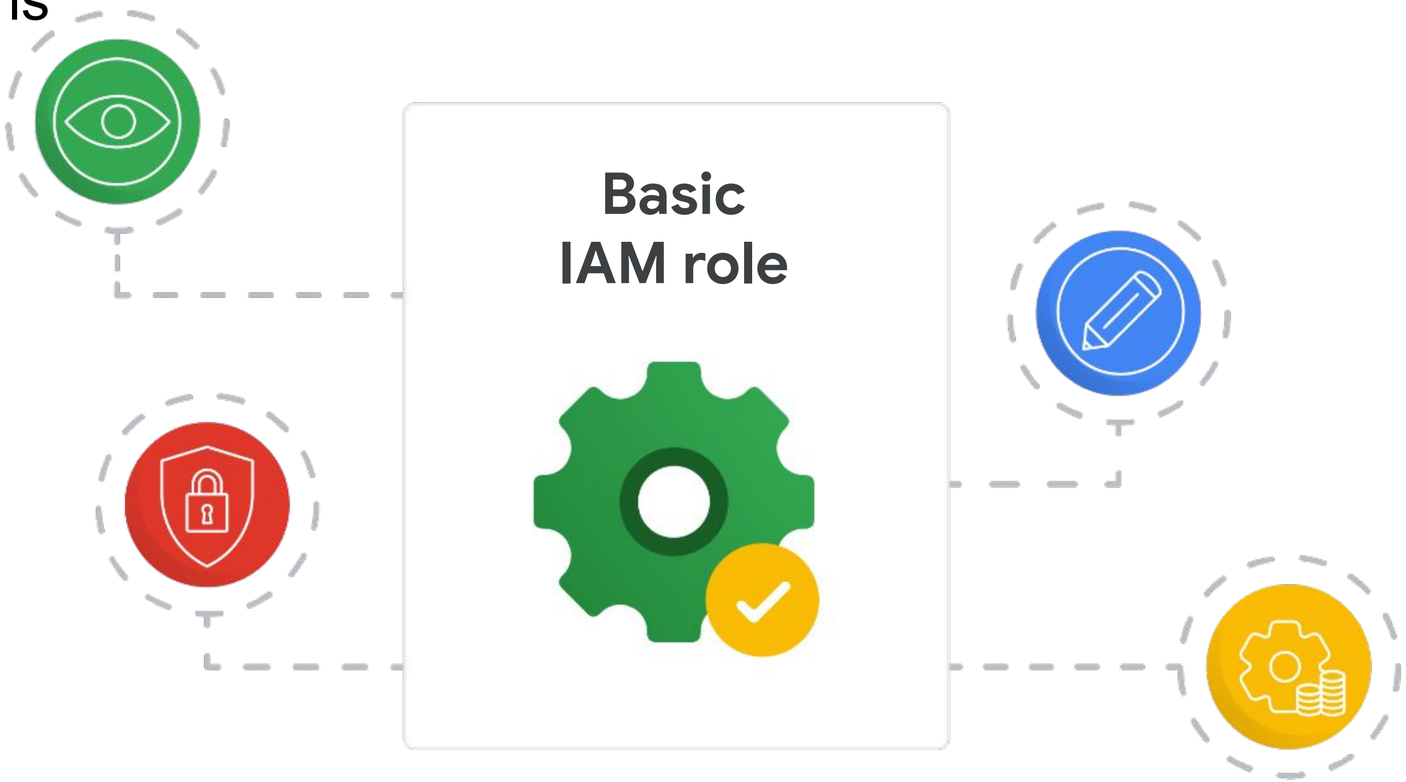
Apply broad permissions across many Google Cloud services

Current basic roles:

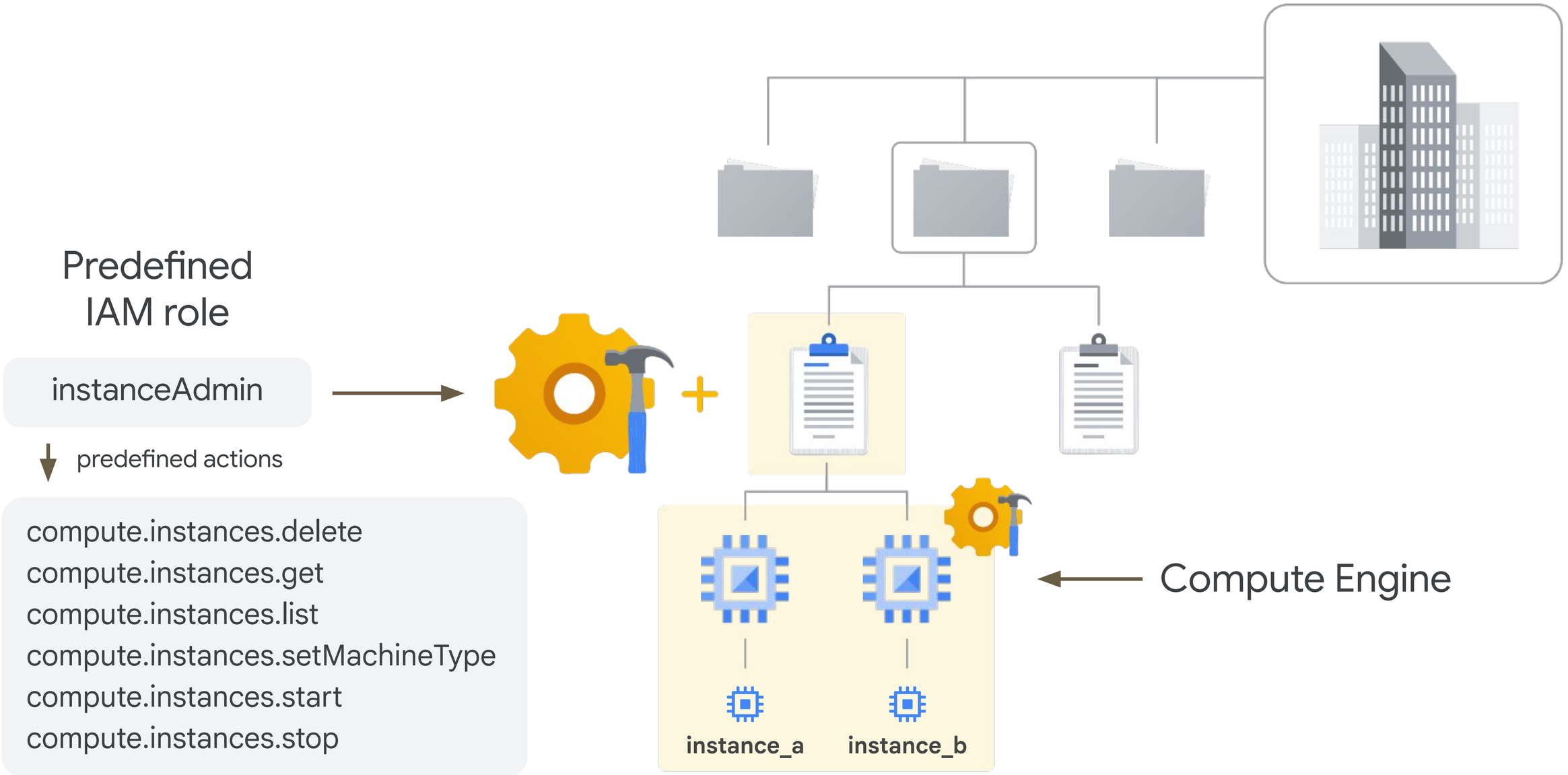
- **Reader** – read-only actions
- **Writer** – read + many modification actions
- **Admin** – broader administrative actions

Legacy basic roles still exist:

- **Viewer**
- **Editor**
- **Owner**



Predefined roles match job needs



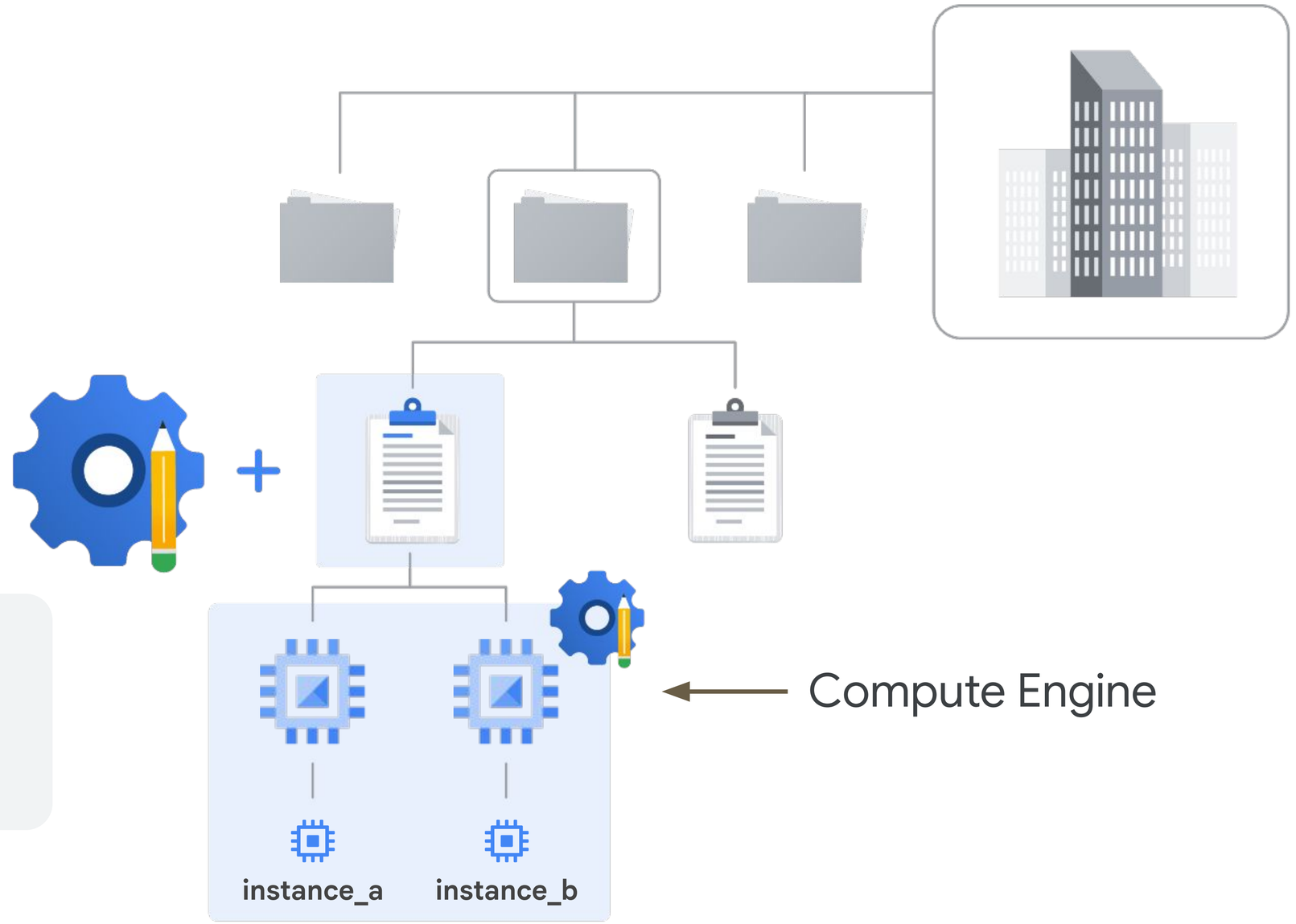
Custom roles are more specific and flexible

Custom
IAM role

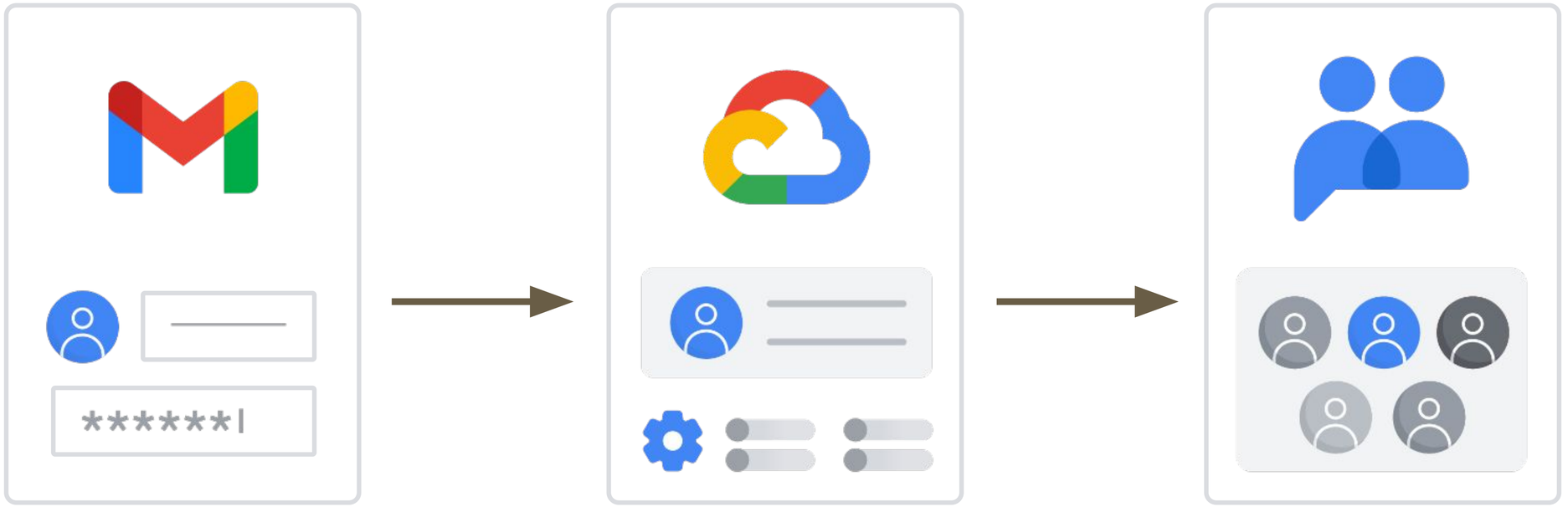
instanceOperator

predefined actions

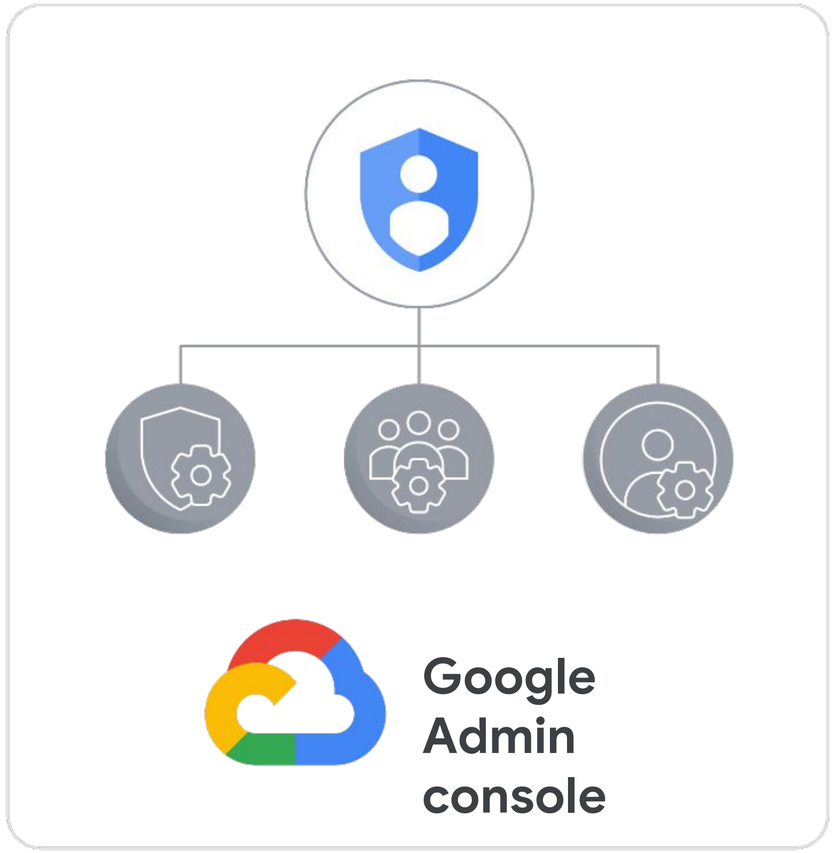
compute.instances.get
compute.instances.list
compute.instances.start
compute.instances.stop



Cloud Identity manages team and organization access

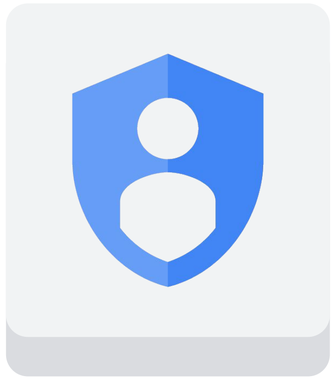


Cloud Identity defines user and group policies



With Cloud Identity, organizations can define policies and manage their users and groups using the Google Admin console

Cloud Identity defines user and group policies

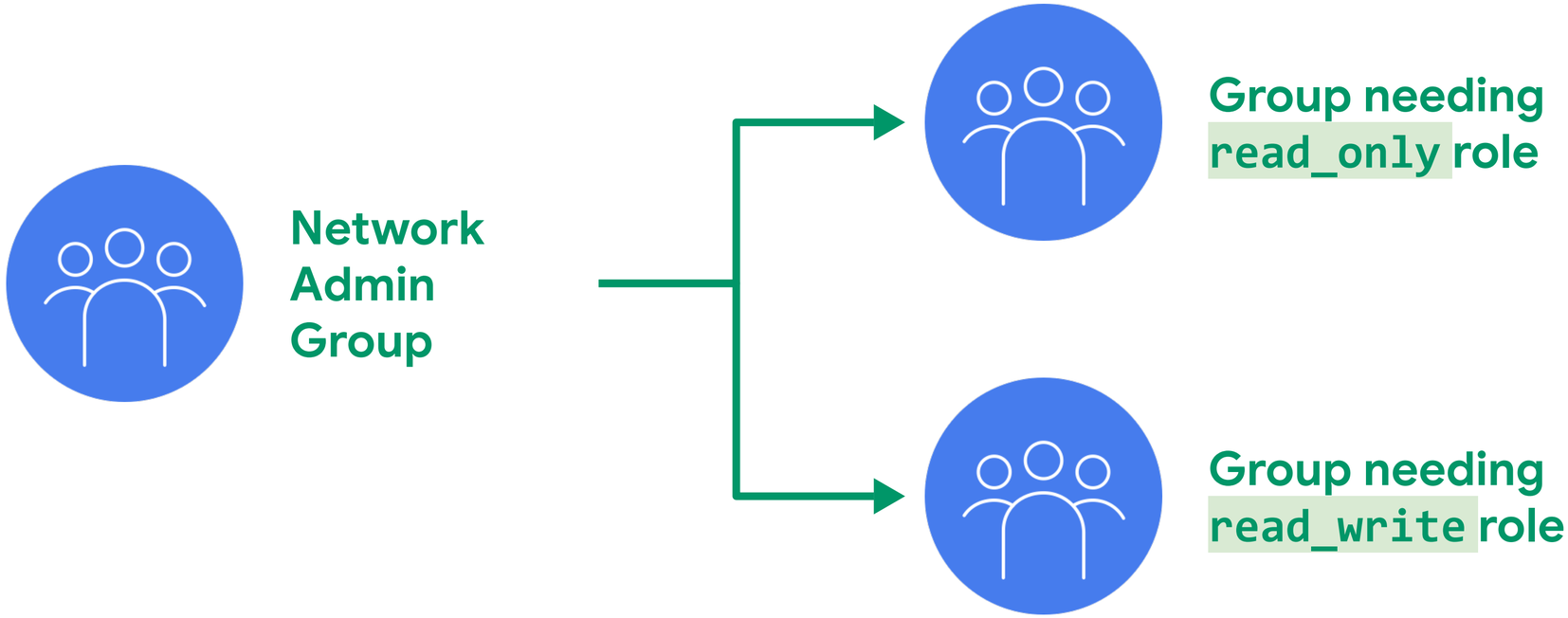


Cloud Identity

- Integrate with existing identity systems such as Active Directory or LDAP through federation or directory synchronization.
- The Google Admin console can be used to disable user accounts and remove them from groups when they leave
- Available in free and premium editions
- Already available to Google Workspace customers in the Google Admin console

What is LDAP

Groups


Network Admin Group
Group needing read_only role
Group needing read_write role

Service Accounts

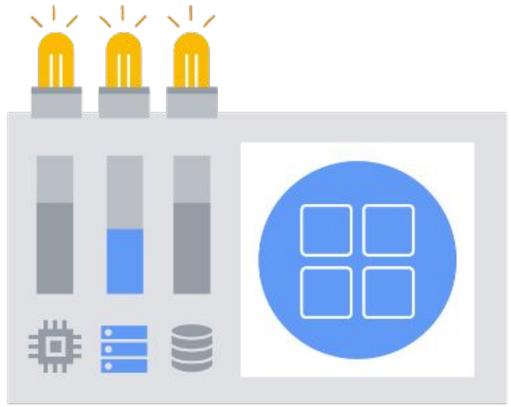
- An identity used by an application, VM, or other workload
- Not a normal human user account
- Give it only the permissions the workload needs
- The workload uses the service account when accessing Google Cloud resources

Service Accounts and IAM



Copyright Google LLC. For educational purposes in accordance with the terms of use set forth on the program Website.

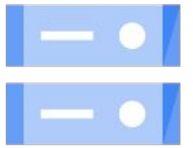
Permissions can be applied to service accounts



Virtual machine

Service account





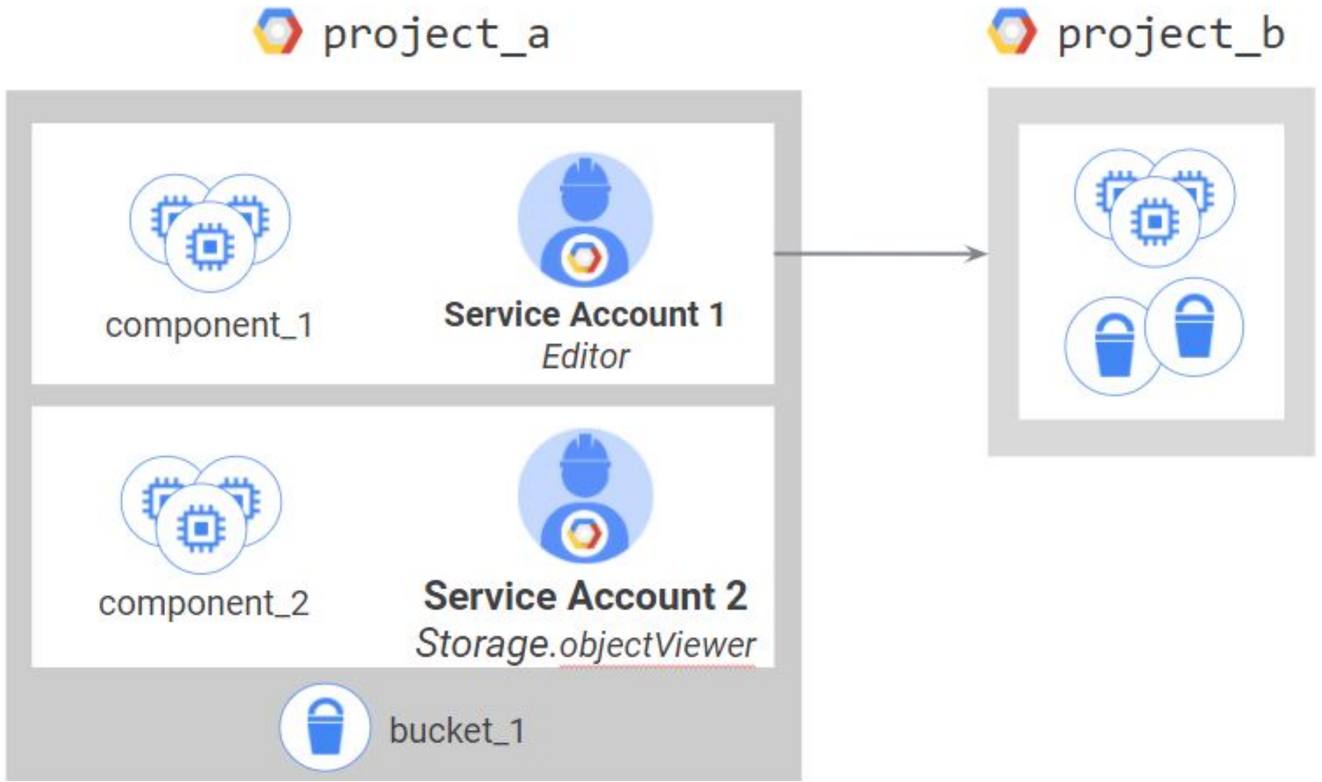
Cloud Storage

Create a service account to authenticate the VM to Cloud Storage

Different VM Components Can Use Different Service Accounts

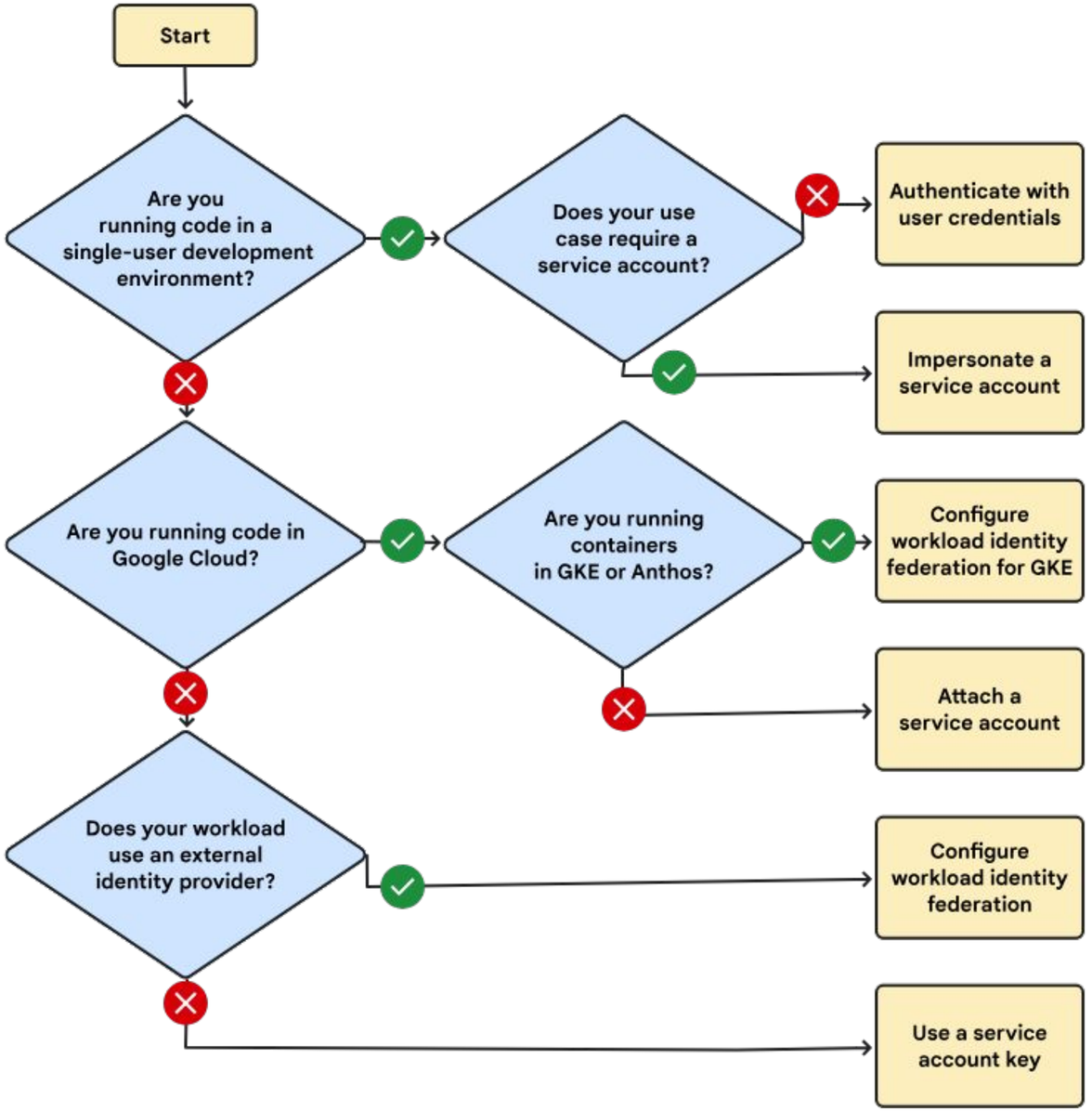
- component_1 uses **Service Account 1** to access resources in project_b
- component_2 uses **Service Account 2** to access bucket_1
- Each service account receives only the permissions its component needs
- Service account permissions can be changed without recreating the VMs

You can grant different groups of VMs in a project different identities



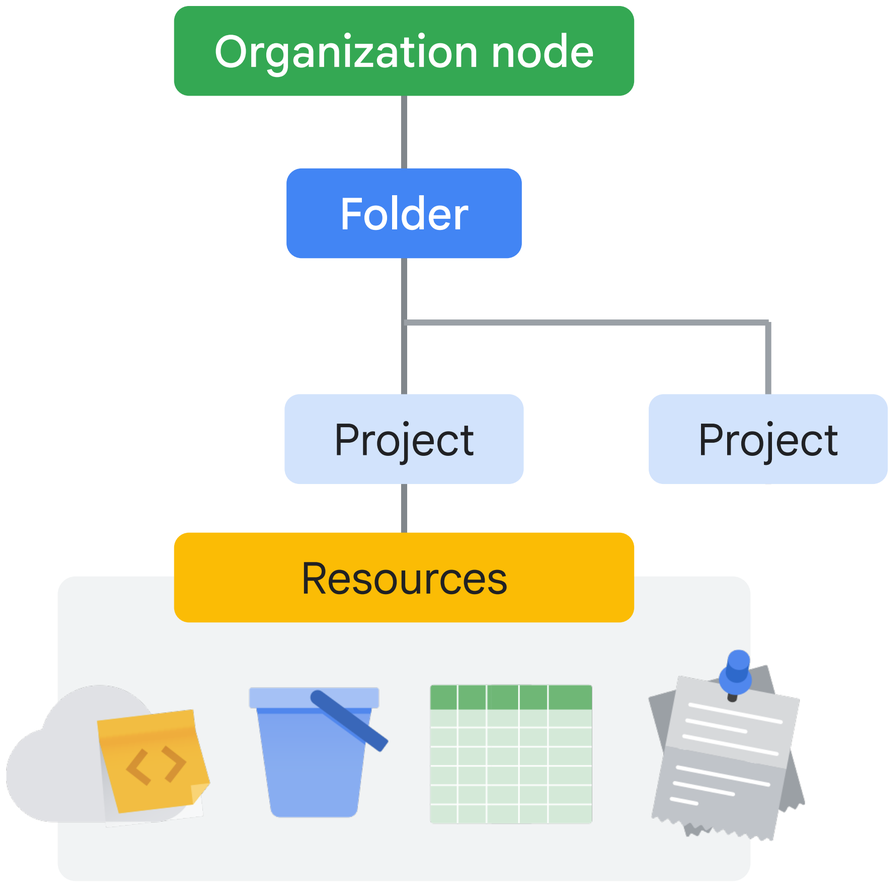
Copyright Google LLC. For educational purposes in accordance with the terms of use set forth on the program Website.

Service Account Authentication Best Practices



Best practices

IAM Best Practices with the Resource Hierarchy



- Use projects to group resources
- Check the policy granted on each resource
- Use "principle of least privilege"
- Audit policies using Cloud Audit Logs
- Audit memberships of groups used in policies

Credentials and Secrets

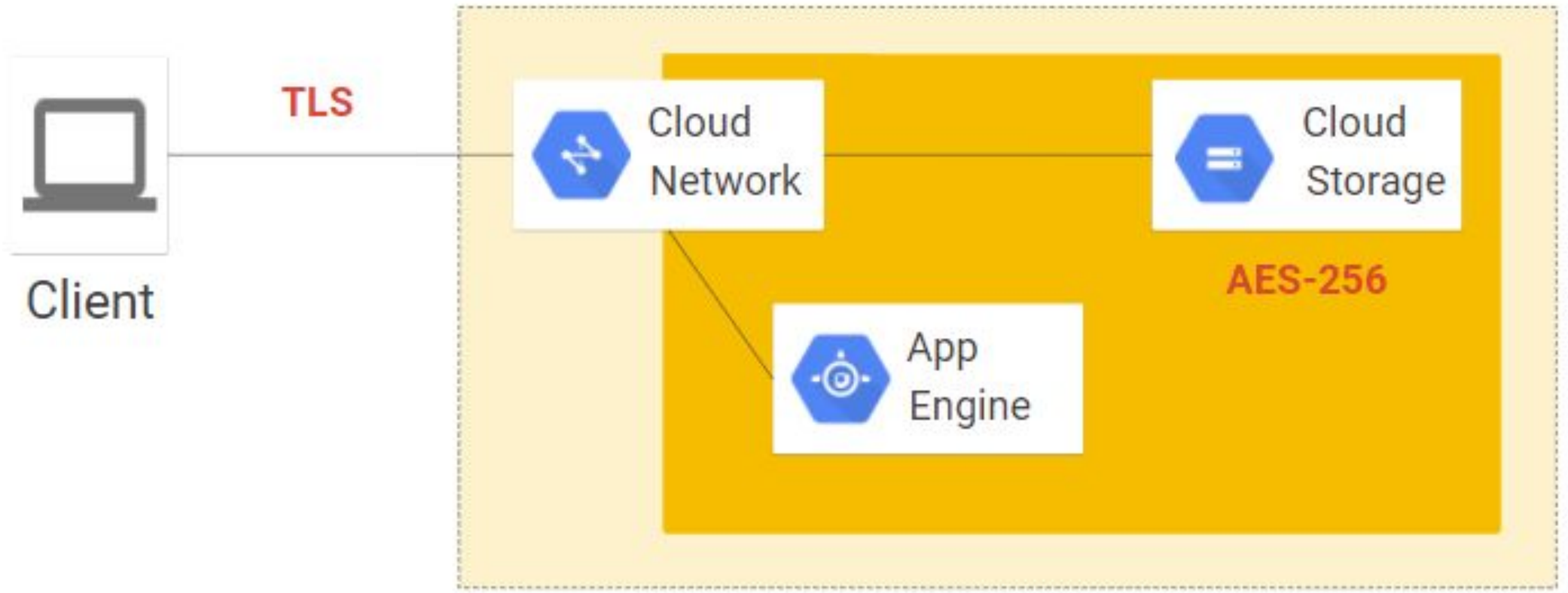
Protecting sensitive information and encryption keys

Encryption

Goes hand-in-hand with security/privacy

- What is encryption?
- What encryption methods or use cases do you know?
- What is the difference between HTTP and HTTPS?

Google Cloud Encrypts Data in Transit and at Rest



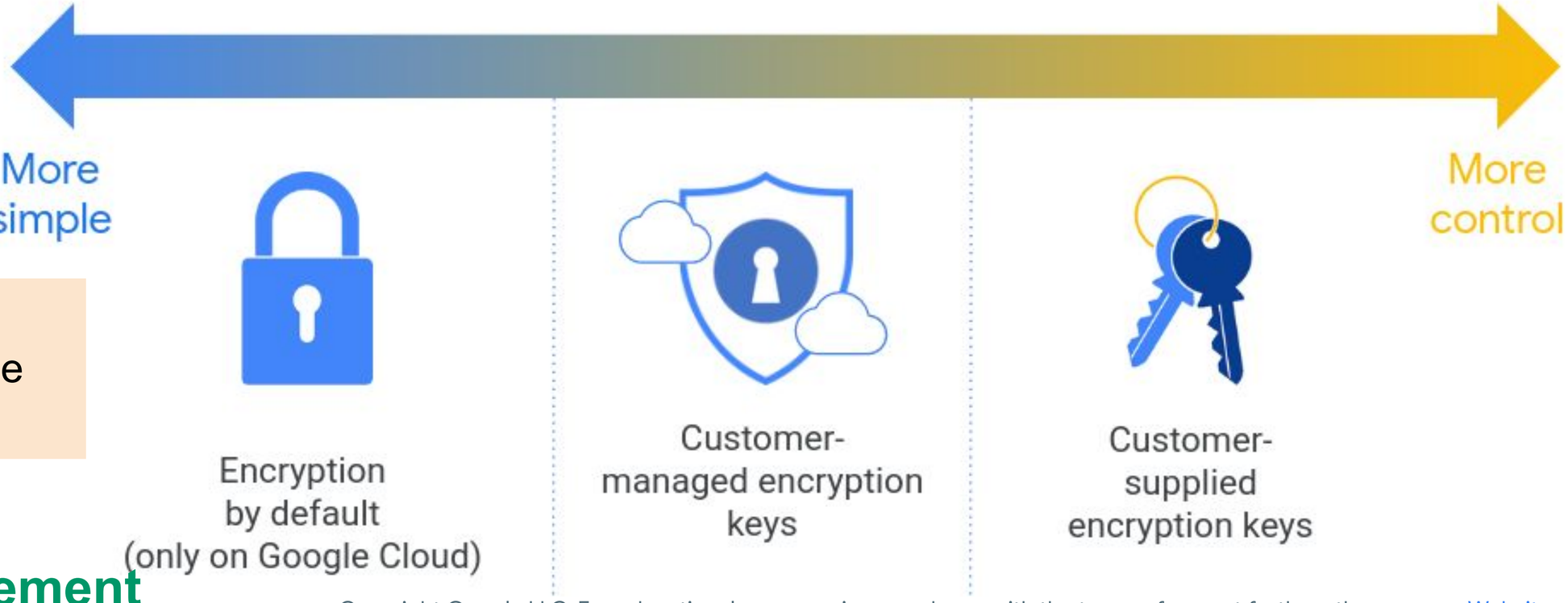
Copyright Google LLC. For educational purposes in accordance with the terms of use set forth on the program Website.

Google Cloud Encryption Key Options

Google default encryption — Google owns and manages the keys

Customer-managed encryption keys (CMEK) — customer controls keys through Cloud KMS

Customer-supplied encryption keys (CSEK) — customer generates and supplies the key material



Note: CSEK support is limited; Compute Engine CSEK is deprecated.

Cloud Key Management

Copyright Google LLC. For educational purposes in accordance with the terms of use set forth on the program Website.

Cloud KMS and Customer-Managed Encryption Keys

- Cloud KMS centrally creates, stores, and manages cryptographic keys
- Supports encryption/decryption and digital signing/verification
- Controls access to keys through IAM
- Supports key rotation and key lifecycle management

Customer-Supplied Encryption Keys (CSEK)

- You generate and manage the key material yourself
- You supply the key when accessing supported Google Cloud services
- Google does not permanently store the supplied key
- More control, but also more responsibility
- CSEK support is limited; Compute Engine CSEK is deprecated

Choosing an Encryption Key Option

Option	Who controls the key?	Management effort
Default encryption	Google	Low
CMEK	Customer through Cloud KMS	Medium
CSEK	Customer manages raw key material	High

Key Rotation

- Periodically create a new key version
- New key version becomes the primary version
- Helps limit exposure if an older key is compromised
- Previous versions may still be needed to decrypt existing data
- Cloud KMS can support automatic rotation for symmetric keys

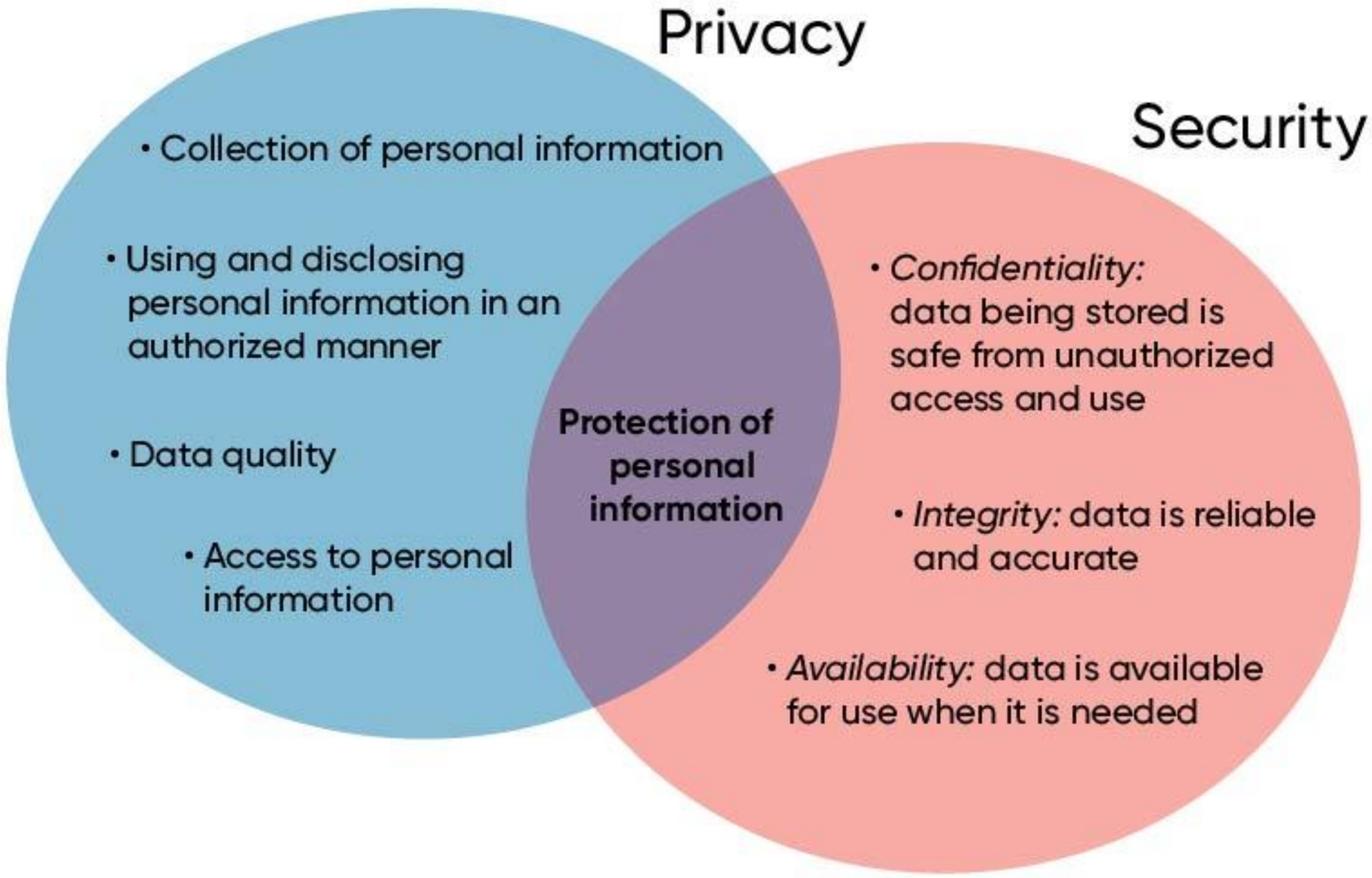
codelab: Encrypt and decrypt data with Cloud KMS

Cloud Security Best Practices

- **Group related resources into projects**
  - Separate environments and trust boundaries
- **Check IAM policies and inherited permissions**
  - Make sure resources do not receive unintended access
- **Use the principle of least privilege**
  - Give users and workloads only the access they need
- **Audit policies regularly**
  - Review changes in users, groups, roles, and permissions
- **Monitor logs and alerts**
  - Look for unusual access or unexpected activity

Security vs. Privacy

What is the difference between security and privacy?



Privacy Responsibilities in the Cloud

- Privacy is a **shared concern**
- Google Cloud provides controls for:
  - Encryption
  - Access control
  - Data residency
  - Auditing and monitoring
- Customers are responsible for:
  - What personal data is collected
  - How it is used and shared
  - Who can access it
  - How long it is retained
  - Meeting applicable privacy regulations

In the security category of the Architecture Framework, you learn to do the following:

- Review shared responsibility and shared fate on Google Cloud
- Understand security principles
- Manage risks with controls
- Manage your assets
- Manage identity and access
- Implement compute and container security
- Secure your network
- Implement data security
- Deploy applications security
- Manage compliance obligations
- Implement data residency and sovereignty requirements
- Implement privacy requirements
- Implement logging and detective controls

Well-Architected Framework

Summary

- Authentication verifies identity; authorization determines permissions
- IAM controls who can do what on which resources
- Use groups, service accounts, and least privilege to manage access
- Protect data with encryption and appropriate key management
- Security and privacy are related but have different responsibilities

Practice: What Would You Do?

- A developer needs to view Cloud Storage objects but should not modify them. **What type of access should you give?**
- Twenty developers need the same permissions on a project.
  Assign the role to each person individually or to a group?
- A Compute Engine VM needs to read from a private Cloud Storage bucket. **Should the application use a developer's personal credentials or a service account?**
- An application component only needs to start and stop VMs, but not delete them. **Would you use a broad role or a narrower/custom role?**
- A company wants to control its encryption keys through Cloud KMS.
  Which option should it use: default encryption, CMEK, or CSEK?

